System Architecture — Blueprint v4 Final

PQC Security Framework & 3-Tier Defense-in-Depth for In-Vehicle CAN-FD Networks

Comprehensive Architectural Contract & Verification Specification | Version 4.0

0. Framing & Scope

This document defines the complete end-to-end security architecture for Phases 1–2 of the CAN-FD Post-Quantum Cryptography (PQC) and Physical Kinematics Intrusion Detection System (IDS). It extends the segmented CAN-FD network model from Castiglione & Elia (2025) while fundamentally replacing three baseline assumptions with verified engineering implementations:

1. Pre-shared static seed → Replaced by hardware-intrinsic SRAM-PUF enrollment and fuzzy extractor secret reconstruction.

2. Semi-trusted local gateways → Replaced by a single, fully-trusted Central Intelligent Security Gateway (CISG).

3. No attestation → Replaced by ML-DSA-44 (FIPS 204) digital signatures transferred over a 41-frame block-transfer burst with 64-bit NACK bitmap recovery.

4. Novel IDS Contribution → Multi-Tier Defense-in-Depth Pipeline integrating NIST SP 800-232 Ascon-AEAD128 wire cryptography, Tier 1.5 discrete boolean invariant gates, and a Tier 2 14D physical kinematics LSTM-Autoencoder with zero-floor anchoring.

1. Component Inventory & Ownership

The ECU performs Ascon-AEAD128 encryption before transmitting. The CISG is the cryptographic termination point for inter-domain traffic and an active inspection authority. The CISG is the sole point in the architecture where decrypted plaintext from other ECUs exists.

Component	Owner	Trust Status	Architectural Role
ECU (Generic Node)	N/A	Authenticated, Monitored	Generates telemetry; encrypts/decrypts traffic using operational session keys (K_i). Monitored continuously for compromised insider behavior.
SRAM-PUF + Fuzzy Extractor	Kunal	Trusted (Hardware Root)	Embedded in ECU. Reconstructs hardware-intrinsic secret for enrollment and HKDF bootstrap key derivation.
Central Gateway (CISG)	All	Fully Trusted (Root of Trust)	Sole routing hub and policy authority. Decrypts AEAD traffic, inspects plaintext, enforces invariants, and re-encrypts.
Session Provisioning	Kunal	Trusted	Handles HKDF derivation of per-boot K_boot_i and Ascon-AEAD128-protected delivery of fresh

			random session key K_i.
ML-DSA Attestation	Kaustuv	Trusted	Generates and verifies post-quantum digital signatures (ML-DSA-44 / FIPS 204) over boot measurement digests.
Indexed Block-Transfer	Kaustuv	Trusted	Fragments 2436B attestation object into 41 frames with 64-bit NACK bitmap selective retransmission.
Secure Data Frame Handler	Tapan	Trusted	Constructs/parses 64B runtime frames, manages 32-bit monotonic freshness counter and associated data.
3-Tier Layered IDS	Tapan	Trusted	Gateway-hosted layered detection: Tier 1 Wire Gate + Tier 1.5 Invariant Gate + Tier 2 14D Physical Kinematics LSTM-AE.
Federated Learning Engine	Tapan	Trusted	Manages privacy-preserving cross-vehicle model updates (Flower / FedAvg) across 5 driving domains. Raw telemetry never leaves vehicle.

2. Domain Segmentation & Trust Model

The vehicle is divided into four distinct electrical CAN-FD domains (Powertrain, Chassis, Body & Comfort, Infotainment). Each domain is an electrically independent broadcast bus connected to the CISG through a dedicated hardware transceiver controller.

> **[LOGICAL PURE-STAR SECURITY ARCHITECTURE]**
> The proposed architecture uses a physically segmented CAN-FD topology rather than a literal star. The Logical Pure Star designation refers to the cryptographic architecture: each ECU possesses a unique session key K_i, and the CISG is the central trusted authority. Intra-domain traffic is passively monitored, while inter-domain traffic is actively gated.

Default-Deny Inter-Domain Routing Policy

Source Domain	Destination Domain	Decision	Security Rationale
Safety (Powertrain/Chassis)	Infotainment	ALLOW	Read-only telemetry (Speed, RPM, Temp to Head Unit display)
Safety (Powertrain/Chassis)	Comfort	BLOCK	No safety telemetry exposed to comfort domain
Comfort (Body & Comfort)	Safety	BLOCK	Comfort ECUs have zero authority over powertrain or chassis dynamics
Infotainment	Comfort	RESTRICTED	Whitelist of non-critical

			commands only (e.g. volume, ambient light)
Infotainment	Safety	BLOCK	Unconditional hard block; zero attack path to vehicle dynamics

3. End-to-End Lifecycle & 3-Tier Defense Pipeline

The complete transaction pipeline consists of 14 sequential stages spanning offline enrollment, authenticated boot, session delivery, runtime wire filtering, discrete invariant gating, and continuous kinematic anomaly inspection:

Stage 1. PUF Enrollment: During manufacturing, ECU reconstructs secret via fuzzy extractor. CISG stores SHA-256(PUF_response) and ML-DSA public key.

Stage 2. Authenticated Boot: At startup, CISG issues plaintext Category 3.1 challenge containing fresh SESSION_ID and 16-byte RANDOM_CHALLENGE.

Stage 3. Bootstrap Key Derivation: Both sides independently derive per-boot K_boot_i using HKDF(salt=RANDOM_CHALLENGE, IKM=SHA-256(PUF_response)).

Stage 4. ML-DSA Attestation: ECU signs boot measurement with ML-DSA-44. Protected 2436B object is transferred in a 41-frame burst with 64-bit NACK bitmap recovery.

Stage 5. Session Key Delivery: Upon signature verification, CISG generates fresh random 128-bit session key K_i and delivers it wrapped in Ascon-AEAD128 under K_boot_i.

Stage 6. Runtime Telemetry: ECU transmits telemetry in 64B Category 1 frames (8B unencrypted AD, 40B ciphertext payload, 16B Ascon tag).

Stage 7. Ingress Decryption: CISG receives frame, uses SENDER_ECU_ID to look up K_i, and attempts decryption.

Stage 7b. Tier 1 Monotonic Counter Gate: Frames rejected outright in O(1) time if C_k <= C_k-1. Defeats replay attacks before invoking ML.

Stage 8. Tier 1 Ascon Tag Gate: CISG verifies 16B tag. If invalid, frame is dropped immediately at line rate. Corrupted ciphertext is never passed to LSTM buffers, eliminating state pollution.

Stage 9. Tier 1.5 Discrete Invariant Gate: Validates discrete boolean invariants (e.g. Reverse Light status vs forward vehicle speed) deterministically.

Stage 10. Tier 2 Kinematic Extraction: Telemetry is parsed into the 14D Physical Kinematics Profile with Leave-One-Out (LOO) wheel differences and zero-floor standstill anchoring.

Stage 11. Tier 2 LSTM Inspection: 30-timestep sliding window evaluated by gateway ONNX LSTM-Autoencoder. Target subsystem channels scored against frozen thresholds (tau_speed, tau_wheel, tau_coolant).

Stage 12. Policy Enforcement: CISG checks Default-Deny routing matrix before forwarding inter-domain traffic.

Stage 13. Re-encryption & Forward: Permitted frames re-encrypted under destination session key K_j with fresh nonce.

Stage 14. Federated Learning Update: Gateway trains on clean profiles; local weights aggregated via Flower / FedAvg across vehicle fleets.

4. Benchmark Validation & Empirical Results

The 3-Tier Architecture was comprehensively benchmarked against the official ROAD (Real ORNL Automotive Dataset) masquerade dataset on Google Colab with Tesla T4 GPU acceleration:

Tier	Attack Subsystem	Scenario	ROC-AUC	Recall	FPR
Tier 1	Cryptographic Gateway	Ascon-128 Tag Corruption	1.0000	100.0%	0.0000%
Tier 1	Sequence Tracking	Monotonic Counter Replay	1.0000	100.0%	0.0000%
Tier 1	Rate Limiter	Bus Flooding DoS (20 kHz)	1.0000	100.0%	0.0000%
Tier 1.5	Reverse Indicator	ROAD: reverse_light_off (3 trials)	0.9508	90.21%	0.0450%
Tier 1.5	Reverse Indicator	ROAD: reverse_light_on (3 trials)	0.9999	100.0%	0.0330%
Tier 2	Speedometer (ID 208)	ROAD: max_speedometer (3 trials)	0.9996	99.96%	0.0470%
Tier 2	Wheel Speeds (ID 1760)	ROAD: correlated_signal (3 trials)	0.9986	100.0%	0.2778%
Tier 2	Coolant Temp (ID 1255)	ROAD: max_engine_coolant	0.9999	93.02%	1.3825%

5. Interface Contracts & Schema Registry

Production CAN-FD schema registry in canfd_schema.py retains 100% backward compatibility while formalizing the 14D physical profile:

14D_PHYSICAL_KINEMATICS_LOO Profile: speed, rpm, steering, brake, wheel_fl, wheel_fr, wheel_rl, wheel_rr, coolant, loo_wheel_fl, loo_wheel_fr, loo_wheel_rl, loo_wheel_rr, speed_wheel_delta.

Active Profile Selector: Defaults to 12D_LEGACY for Phase 1 unit-test suites. Phase 2 gateway initializes GatewayIDSExtractor(profile="14D_PHYSICAL_KINEMATICS_LOO").

6. Document Changelog

Version	Release	Summary of Architectural Changes

v1	Initial Draft	Baseline segmented CAN architecture (Sections 0–2).
v2	Milestone 1	Added Sections 3–6 and initial Word document.
v3	Milestone 2	Added Logical Pure-Star over Segmented Domains, reordered bootstrap key derivation before attestation, added 14-stage lifecycle pipeline, and aligned 12D vector with canfd_schema.py.
v4	Final Verification	Harmonized 3-Tier Defense-in-Depth Architecture: Formalized Tier 1 Ascon-128 line-rate drop & Monotonic Gate, integrated Tier 1.5 Discrete Invariant Gate, codified Tier 2 14D Physical Kinematics Profile with LOO wheel kinematics and zero-floor standstill scaling (0.9999 ROC-AUC on ROAD benchmarks).